Plateforme de supervision et de réponse aux incidents basée sur Wazuh

Conception, mise en œuvre et validation d'un laboratoire SOC

Selma | Master Audit et Sécurité Informatique, FSEG Sfax | Octobre 2026

Résumé

Ce rapport présente un laboratoire de cybersécurité défensive construit autour de Wazuh, plateforme open source de supervision de la sécurité (SIEM/XDR). Le laboratoire collecte la télémétrie de plusieurs systèmes, détecte les comportements suspects, enrichit les alertes par de la threat intelligence, notifie l'analyste en temps réel et déclenche des actions de confinement automatiques. Chaque capacité a été validée par un scénario de test contrôlé, dans un environnement virtualisé isolé. Le document décrit l'architecture, la mise en œuvre, les résultats obtenus, les difficultés rencontrées et la correspondance avec MITRE ATT&CK et ISO/IEC 27001:2022.

1. Contexte et problématique

Les systèmes d'information produisent en continu des événements : authentifications, exécutions de processus, modifications de fichiers. Analysés isolément, ils sont inexploitables à grande échelle. Un centre opérationnel de sécurité (SOC) les centralise, repère les activités anormales et coordonne la réponse. Le délai entre la détection et le confinement conditionne l'impact d'un incident : le réduire par l'automatisation est un enjeu majeur.

Problématique. Comment construire, avec des outils open source, une chaîne complète de détection et de réponse, et démontrer son fonctionnement de manière reproductible ?

2. Objectifs

- Centraliser la supervision de plusieurs endpoints Windows et Linux.
- Collecter une télémétrie détaillée (processus, fichiers, authentifications).
- Détecter les modifications de fichiers et les comportements suspects.
- Enrichir les alertes avec une source de threat intelligence externe.
- Notifier l'analyste en temps réel, sans surveillance continue du tableau de bord.
- Automatiser le confinement sur Linux (réseau) et sur Windows (fichier).
- Valider chaque capacité par un test contrôlé et en conserver les preuves.

3. Architecture

Système	Rôle
Serveur Wazuh (Ubuntu, 192.168.56.102)	Manager (analyse et règles), Indexer (stockage), Dashboard (visualisation), Filebeat (acheminement des alertes)
Endpoint Windows 11	Agent Wazuh, Sysmon, surveillance d'intégrité des fichiers, réponse de quarantaine
Endpoint Ubuntu	Agent Wazuh, journaux d'authentification SSH et sudo
Kali Linux	Machine d'attaque contrôlée (Hydra), sans agent
VirusTotal	Service externe d'analyse de réputation des fichiers
Discord	Canal de notification de l'analyste

Le fonctionnement suit un flux unique : les agents transmettent leurs événements au manager, qui les analyse par décodeurs et règles ; les alertes sont indexées puis affichées dans le tableau de bord ; selon la règle déclenchée, le manager interroge VirusTotal, notifie Discord et peut ordonner une action de réponse à l'agent concerné.

Flux fonctionnel : Monitor → Detect → Enrich → Notify → Respond → Contain.

L'ensemble s'exécute dans un réseau virtuel privé. Les attaques simulées visent uniquement les machines du laboratoire, et le serveur dispose d'un accès Internet pour interroger les services externes.

4. Mise en œuvre

4.1 Collecte de télémétrie

Des agents Wazuh sont déployés sur les endpoints Windows 11 et Ubuntu et enregistrés auprès du manager. L'enregistrement est validé dans le tableau de bord par l'état actif des agents.

4.2 Sysmon

Sysmon enrichit les journaux Windows avec la création de processus (ID 1), les connexions réseau (ID 3) et la création de fichiers (ID 11). L'agent collecte le canal Microsoft-Windows-Sysmon/Operational. Exemple observé : le lancement de cmd.exe par

un processus inhabituel génère la règle 92052, associée à la technique MITRE T1059.003.

4.3 Surveillance d'intégrité des fichiers (FIM)

Un dossier de test est surveillé en temps réel par le module syscheck. Les créations, modifications et suppressions produisent respectivement les règles 554, 550 et 553.

4.4 Enrichissement par VirusTotal

L'intégration est appliquée aux alertes du groupe syscheck : l'empreinte du fichier détecté est soumise à VirusTotal. Lorsque des moteurs signalent le fichier, la règle 87105 (niveau 12) est générée. Le fichier de test EICAR, standard dédié aux tests de détection et inoffensif, a été reconnu par 66 moteurs sur 68.

4.5 Notification Discord

Une intégration personnalisée, composée d'un lanceur et d'un script Python, met en forme l'alerte en message structuré : agent, sévérité, règle, description, technique MITRE, fichier ou IP concernés et action de réponse associée. Seules les alertes de niveau 8 et plus sont transmises, et les champs vides sont omis pour garder un message lisible.

4.6 Réponses automatiques (Active Response)

Linux : blocage d'adresse IP. Lorsque la règle 5712 détecte un brute force SSH, la commande firewall-drop ajoute une règle de pare-feu bloquant l'IP source pendant 300 secondes, puis la retire automatiquement.

Windows : quarantaine de fichier. Lorsque la règle 87105 se déclenche, un lanceur .cmd appelle un script PowerShell qui lit le chemin du fichier dans l'alerte VirusTotal, le déplace vers un dossier de quarantaine sous un nom horodaté et consigne l'opération dans un journal. Le fichier est conservé, non supprimé, pour permettre l'investigation.

5. Validation et résultats

Scénario de test	Résultat attendu	Résultat obtenu
Activité Sysmon (création de processus)	Alerte avec correspondance MITRE	Règle 92052, T1059.003
Création, modification, suppression de fichier	Alertes FIM	Règles 554, 550, 553
Dépôt du fichier EICAR	Enrichissement VirusTotal et alerte critique	Règle 87105, niveau 12, 66 moteurs sur 68

Scénario de test	Résultat attendu	Résultat obtenu
Brute force SSH depuis Kali (Hydra)	Règle 5712 et blocage de l'IP source	IP bloquée 300 s puis débloquée
Alerte de niveau 8 ou plus	Message Discord structuré	Message reçu avec les champs attendus
EICAR après alerte 87105	Fichier déplacé en quarantaine et journalisé	Fichier horodaté en quarantaine, entrée SUCCESS dans le journal

Chaque test dispose d'une capture d'écran, d'un journal ou des deux, conservés dans le dépôt du projet.

6. Difficultés rencontrées et résolutions

Problème	Cause	Résolution
Tableau de bord vide malgré des alertes générées	Service Filebeat arrêté, template d'index absent	Diagnostic par l'état du service et l'API de l'indexer, rechargement du template
Un même fichier produit deux événements FIM	Création d'un fichier vide, puis écriture du contenu	Seule la seconde empreinte est reconnue par VirusTotal (65 à 66 sur 68) et déclenche la réponse
Requêtes VirusTotal sans résultat	Quota de l'offre gratuite (4 requêtes par minute)	Tests espacés
Quarantaine non exécutée au premier essai	L'agent n'avait pas encore rechargé sa configuration de réponse	Test du script isolé, puis de la chaîne complète après synchronisation

7. Correspondance MITRE ATT&CK et ISO/IEC 27001:2022

Détection ou capacité	MITRE ATT&CK	Contrôle ISO/IEC 27001:2022
Création de processus suspecte (règle 92052)	T1059.003	A.8.16 Surveillance

Détection ou capacité	MITRE ATT&CK	Contrôle ISO/IEC 27001:2022
Modification de fichier (règle 550)	T1565.001	A.8.15 Journalisation
Fichier malveillant (règle 87105)	T1203	A.8.7 Protection contre les malwares
Brute force SSH (règle 5712)	T1110	A.8.16 Surveillance, A.5.26 Réponse aux incidents
Notification et confinement automatiques	-	A.5.24 à A.5.26 Gestion des incidents

Cette grille relie la mise en œuvre technique aux contrôles d'un système de management de la sécurité de l'information : chaque brique du laboratoire constitue une preuve opérationnelle d'un contrôle de l'Annexe A.

8. Analyse critique et limites

- **Statut de la réponse.** Le champ « Actions Taken » des notifications indique qu'une réponse est déclenchée, non qu'elle a réussi. La preuve de succès repose sur l'état du système et sur le journal de quarantaine.
- **Représentativité des tests.** EICAR et le brute force simulé valident la chaîne technique, mais ne remplacent pas des scénarios d'attaque réalistes.
- **Dépendance à un service externe.** L'enrichissement dépend de la disponibilité et du quota de l'API VirusTotal.
- **Risque de faux positifs.** Un blocage ou une quarantaine automatique peut perturber un usage légitime : d'où le blocage temporaire et la conservation du fichier plutôt que sa suppression.
- **Configuration de test.** Des exclusions antivirus limitées aux dossiers de test ont été nécessaires et sont retirées en fin de laboratoire.

9. Perspectives

- Exploiter les alertes de confirmation d'Active Response pour distinguer une réponse déclenchée d'une réponse réussie.
- Développer des règles de détection personnalisées et ajuster le bruit des alertes.
- Rejouer des scénarios d'attaque documentés (Atomic Red Team) pour mesurer la couverture MITRE.
- Intégrer une plateforme d'orchestration et de gestion de cas (Shuffle, TheHive).

10. Conclusion

Le laboratoire démontre une chaîne SOC fonctionnelle de bout en bout : collecte, détection, enrichissement, notification et confinement automatique, sur des systèmes Windows et Linux. Les difficultés rencontrées et leur résolution ont permis d'en comprendre les points de fragilité : acheminement des alertes, comportement du FIM, quotas des services externes, synchronisation des réponses actives. La correspondance avec MITRE ATT&CK et ISO/IEC 27001:2022 place ce travail à l'interface de l'ingénierie de détection et de l'audit de sécurité.

Références

- Documentation Wazuh : documentation.wazuh.com
- MITRE ATT&CK : attack.mitre.org
- ISO/IEC 27001:2022, Annexe A
- Microsoft Sysinternals, Sysmon
- VirusTotal, API de réputation de fichiers
- EICAR, fichier de test antivirus standard

Annexe : dépôt du projet

Scripts, extraits de configuration sans secrets et captures de validation : github.com/SelmaBorgi/wazuh-soc-lab